

Sistem za detekciju prevara u bankarskim transakcijama

Sistem zasnovan na pravilima (Drools)

Članovi tima

- Milica Radić

Motivacija

Prevare u bankarskim transakcijama su sve veći problem u finansijskom sektoru. Gubici u svetu prelaze 30 milijardi dolara godišnje, a načini na koje prevaranti rade postaju sve sofisticiraniji — od krađe kartica, preko preuzimanja tuđih naloga, pa sve do prevara u kojima žrtva sama, pod uticajem manipulacije, pošalje novac.

Stari sistemi koji rade po fiksnim pravilima (na primer „blokiraj svaku transakciju veću od 1000€“) više nisu dovoljni. Oni prave previše lažnih alarma, a istovremeno propuštaju ozbiljne prevare koje se prepoznaju tek kroz obrazac ponašanja. S druge strane, sistemi koji koriste veštačku inteligenciju često ne mogu da objasne zašto su nešto označili kao sumnjivo, što je problem i za zakon i za poverenje klijenata.

Sistem zasnovan na pravilima rešava oba problema: pravila su jasna i razumljiva, lako se menjaju kada se pojavi nova vrsta prevare, a mogu da prate i ponašanje klijenta kroz vreme.

Pregled problema

Cilj ovog sistema je da u realnom vremenu prepozna i klasifikuje sumnjive bankarske aktivnosti. Fokus je na četiri glavne vrste prevara:

- **Kartične prevare** — zloupotreba kartica na POS terminalima, online plaćanjima i bankomatima, kao i takozvani „card testing“ napadi gde prevarant izvršava više malih transakcija da bi proverio da li ukradena kartica radi.
- **Preuzimanje naloga** — neko je došao do tuđih pristupnih podataka i koristi nalog sa novog uređaja, menja lozinku, dodaje nove primaocce.
- **Pranje novca kroz lance transfera** — novac brzo ulazi i izlazi sa naloga, šalje se mnogim primaocima u malim iznosima, ili se odjednom aktivira nalog koji je dugo bio neaktivan.
- **Autorizovane prevare** — žrtva sama izvrši transfer jer je neko prevario (lažni inspektor, lažna investicija). Ovo je najteža kategorija jer transakciju zaista odobrava pravi vlasnik naloga.

Pregled literature pokazuje da postojeća komercijalna rešenja (na primer SAS Fraud Management, FICO Falcon, Feedzai) kombinuju mašinsko učenje sa pravilima, ali su zatvorenog koda — ne može se videti kako rade niti se mogu prilagoditi specifičnim potrebama. Akademska istraživanja uglavnom koriste mašinsko učenje (random forest, neuronske mreže, autoencoder-i) koje daje dobre rezultate, ali ima dva problema: ne može da objasni svoje odluke

i sporo se prilagođava novim vrstama prevara jer zahteva ponovnu obuku modela. Ovo rešenje prevazilazi te slabosti:

1. **Objašnjava svaku odluku.** Kada model mašinskog učenja označi transakciju kao prevaru, ne može se reći zašto. Ovde se za svaku odluku može videti tačan lanac pravila koji je do nje doveo, što je važno i zbog regulative (GDPR, PSD2) i zbog poverenja klijenata.
2. **Prati i obrasce u vremenu, a ne samo pojedinačne transakcije.** Mnoge prevare se prepoznaju tek kada se gleda šira slika — pet malih transakcija u 60 sekundi ili plaćanje u dve države u kratkom razmaku. CEP modul to omogućava.
3. **Brzo se prilagođava novim vrstama prevara.** Mašinsko učenje zahteva prikupljanje novih primera i ponovnu obuku modela. Ovde analitičar može da doda novo pravilo ili promeni prag kroz template, i sistem ga koristi odmah.
4. **Omogućava analitičaru da postavlja pitanja sistemu.** Kroz backward chaining analitičar može da pita „da li je ovaj klijent žrtva preuzimanja naloga?“ i sistem proverava sve dokaze i vraća lanac koji to potvrđuje ili opovrgava.

Metodologija rada

Sistem ima tri tipa korisnika:

- Klijent banke
- Analitičar prevara (fraud analyst)
- Administrator sistema

Klijent

Klijent koristi normalne bankarske usluge (kartično plaćanje, online prenos, ATM podizanje, prijava na e-banking). U slučaju da sistem detektuje sumnjivu aktivnost, klijent dobija notifikaciju (push/SMS) sa zahtevom za potvrdu (step-up autentifikacija) ili obaveštenje o blokadi. Klijent ne komunicira direktno sa sistemom pravila — komunikacija se odvija kroz aplikaciju banke.

Analitičar prevara

Analitičar dobija listu transakcija i klijenata označenih kao srednji ili visoki rizik. Za svaki slučaj može da vidi listu pokrenutih pravila, agregirane statistike klijenta, kao i da pokrene dijagnostički upit unazad („zašto je ovaj klijent označen kao moguća žrtva account takeover napada?“). Analitičar potvrđuje, odbacuje ili eskalira slučaj.

Administrator

Administrator održava bazu znanja: dodaje zemlje na crnu/sivu listu, definiše segmente klijenata (VIP, redovni, mladi, penzioneri), menja cut-off vrednosti i pragove kroz mehanizam template pravila, dodaje nova pravila za novonastale šeme prevara.

Ulaz u sistem

Ulaz u sistem čine sledeći tokovi podataka:

- **Statički podaci o klijentu** — godine, segment (VIP/redovni/mladi/penzioner), datum otvaranja računa, država prebivališta, prosečan mesečni promet, lista poznatih primalaca, lista poznatih uređaja.
- **Stream transakcija u realnom vremenu** — svaka transakcija sadrži: ID klijenta, iznos, valutu, vreme, kanal (POS/online/ATM/transfer), lokaciju (zemlja, grad, IP), merchant ID i kategoriju, ID uređaja.
- **Stream login događaja** — vreme, IP, geo-lokacija, fingerprint uređaja, rezultat (uspeh/neuspeh), tip autentifikacije.
- **Promene na nalogu** — promena lozinke, dodavanje novog primaoca, povećanje limita, promena kontakt podataka.
- **Eksterne liste** — crna lista zemalja/IP-ova/merchant-a, lista poznatih „mula“ računa, lista kompromitovanih kartica iz dark weba.

Izlaz iz sistema

Izlazi sistema su gradirani prema nivou rizika, pri čemu se akcije eskaliraju sa rastom skora rizika:

- **Nizak rizik (skor 0–30):** transakcija prolazi normalno, događaj se loguje za buduću analizu obrazaca, profil klijenta se ažurira.
- **Srednji rizik (skor 30–60):** transakcija prolazi, ali se kreira upozorenje (alert) u redu za pregled analitičaru. Klijent može dobiti informativnu notifikaciju.
- **Visok rizik (skor 60–85):** transakcija se blokira do potvrde, klijent dobija step-up autentifikaciju (SMS kod ili push potvrda u aplikaciji), analitičar dobija prioritetni alert.
- **Kritičan rizik (skor 85+):** automatska blokada transakcije, privremeno zamrzavanje naloga, hitan poziv klijentu od strane banke, prijava nadležnoj službi za sprečavanje pranja novca (AML) kada je potrebno.

Pored ovoga, sistem proizvodi dijagnostičke izveštaje (rezultat backward chaining-a) i statističke izveštaje (query) o trendovima prevara.

Baza znanja

Pravila su grupisana po kategorijama prevara i nivoima rezonovanja.

1. Inicijalni profil klijenta (otvaranje računa)

Kada se klijent otvori ili kada sistem prvi put obrađuje postojećeg klijenta, prikupljaju se osnovni podaci: starost, segment (VIP/redovni/mladi/penzioner), država prebivališta, prosečan mesečni promet, lista poznatih uređaja, lista poznatih primalaca. Klijentu se dodeljuje povišen profil rizika ukoliko:

- Račun je otvoren u poslednjih 30 dana i odmah ima visok obrt (tipičan obrazac za „mula“ račune).
- Klijent pripada segmentu „mladi“ (18–25) ili „penzioneri“ (65+) — statistički su češće žrtve socijalnog inženjeringa.

- Država prebivališta je na sivoj listi visokorizičnih jurisdikcija (FATF lista).
- Klijent je u poslednjih 12 meseci već imao potvrđen slučaj prevare.
- Klijent ima istoriju neuspelih KYC (Know Your Customer) provera.

2. Kartične prevare (POS, online, ATM)

Kada stigne kartična transakcija, sistem nad njom izračunava izvedene atribute (poređenje sa istorijom klijenta, vreme, lokacija, merchant kategorija, status uređaja) i nad tokom nedavnih transakcija proverava obrasce ponašanja. Transakcija se označava kao sumnjiva ukoliko:

- Ako iznos transakcije prelazi 5x prosečan iznos klijenta → označi kao abnormalno visoka.
- Ako se transakcija dešava između 02:00 i 05:00 lokalno → označi kao neuobičajeno vreme (osim za klijente koji često rade u tom periodu).
- Ako je transakcija iz zemlje na sivoj listi → označi kao rizična lokacija.
- Ako je merchant kategorija visokog rizika (kockanje, kripto-menjačnice, prepaid kartice) → označi kao rizičan merchant.
- Ako se transakcija dešava sa novog (do sada nezabeleženog) uređaja → označi kao nepoznat uređaj.

3. Preuzimanje naloga (Account Takeover)

Najopasniji scenario jer napadač ima legitiman pristup nalogu nakon što kompromituje pristupne podatke. Sistem prati login događaje, promene na nalogu i transakcije, i kombinuje ove informacije iz vremenskog prozora od 7 dana kako bi prepoznao karakterističnu signaturu napada. Klijentu se dodeljuje rizik od preuzimanja naloga ukoliko:

- Sistem detektuje 5 ili više neuspelih prijava na nalog u roku od 5 minuta (CEP burst) → flag brute force pokušaj.
- Uspešna prijava se desi sa uređaja koji nije u listi poznatih uređaja klijenta → flag nepoznat uređaj (težina 15).
- Prijava dolazi iz zemlje koja je geografski nemoguće daleko od poslednje aktivnosti (impossible travel — CEP) → flag nemoguće putovanje.
- Klijent menja lozinku, email ili broj telefona u roku od 24h od sumnjive prijave → flag izmena kontakt podataka.
- Klijent dodaje novog primaoca (posebno ka inostranom računu) u roku od 24h od sumnjive prijave → flag novi primalac.
- Pokušava se transfer ka novom primaocu sa visokim iznosom → eskalacija na kritičan rizik.

Backward chaining hipoteza „Account Takeover“ se aktivira kada analitičar ili sistem postavi upit i traži kombinaciju ovih dokaza unutar vremenskog prozora od 7 dana. (Detaljan query dat je u sekciji Backward chaining.)

4. Money mule račun (pranje novca kroz lance transfera)

Mula nalozi su računi (često otvoreni od strane prevarom regrutovanih lica) koji se koriste za prosleđivanje novca iz nelegalnih izvora ka krajnjim korisnicima. Sistem prati životni ciklus naloga, obrasce priliva i odliva, kao i karakteristike primalaca u vremenskom prozoru od 48 sati. Klijentu se dodeljuje rizik mula naloga ukoliko:

- Račun je otvoren u poslednjih 6 meseci ILI je bio neaktivan više od 90 dana, a zatim odjednom postaje aktivan → flag sumnjiva aktivacija.
- Stiže priliv značajnog iznosa od ranije nepoznatog uplatioca → flag neočekivani priliv.
- U poslednjih 24h broj različitih primalaca je veći od 10 (accumulate), a prosečan iznos je manji od 200€ → flag muling obrazac.
- Odnos odliva i priliva u poslednjih 48h je veći od 0.9, a istorijski je bio ispod 0.3 → flag pass-through aktivnost.
- Više od 3 primaoca su novootvoreni računi ili računi u inostranstvu → flag sumnjivi primaoci.

Backward chaining hipoteza „Money Mule“ potvrđuje slučaj kada se okupe navedeni dokazi i, dodatno, kada postoji **lanac prosleđivanja** novca kroz proizvoljno mnogo posrednika. Taj lanac se proverava rekurzivnim upitom (videti sekciju Backward chaining) i prijavljuje AML službi.

5. Autorizovana prevara — APP scam (socijalni inženjering)

Najsuptilniji slučaj prevare jer pravi vlasnik naloga sam izvršava transfer pod uticajem prevare (lažni inspektor, lažna investicija, lažni rođak u nevolji). Sistem prati ne samo samu transakciju, već i ponašanje klijenta u kratkom periodu pre nje, tražeći suptilne indikatore stresa i odstupanja od uobičajenog obrasca. Transakciji se dodeljuje rizik autorizovane prevare ukoliko:

- Transfer ide ka primaocu koji nije ranije korišćen → flag prvi transfer ka primaocu.
- Iznos transfera je značajno veći od istorijskog proseka klijenta ($>3x$) → flag neuobičajen iznos.
- Klijent je u kratkom vremenu pre transfera obavljao neuobičajene radnje (više pretraga limita, čitanje uputstva za hitne prenose, više neuspelih transfera) → flag obrazac pod stresom.
- Klijent pripada osetljivom segmentu (mladi 18–25 ili stariji od 65) → multiplikator $\times 1.3$ na ukupan skor.
- Primalac je račun u zemlji bez čvrste regulative ili kripto-menjačnica → flag rizičan primalac.

Kada se zadovolje uslovi, sistem ne blokira automatski (transakcija je formalno autorizovana), već pokreće „cooling-off“ mehanizam — odlaže transfer 24h i kontaktira klijenta sa pitanjima kako bi se proverilo da li je pod uticajem prevare.

6. Sinteza skora rizika i odluka o akciji (gornji nivoi ulančavanja)

Pošto pravila iz prethodnih scenarija proizvedu flegove sa pripisanim težinama, sistem izračunava ukupan skor rizika klijenta i donosi odluku o akciji koja se preduzima. Skor i akcija se određuju na sledeći način:

- Bazni skor klijenta računa se kao zbir težina svih aktivnih flegova u poslednjih 24h.

- Ako klijent pripada VIP segmentu, skorovi za male iznose se umanjuju za 20% (manja verovatnoća prevare).
- Ako se kombinuju 3 ili više kritičnih flegova, primenjuje se multiplikator 1.2 (kombinacija je sumnjivija od proste sume).
- Ako je skor 0–30 → loguj događaj, prosledi transakciju normalno.
- Ako je skor 30–60 → kreiraj alert za analitičara, dodaj klijenta na watchlist 24h.
- Ako je skor 60–85 → blokiraj transakciju, traži step-up autentifikaciju (SMS kod ili push potvrda).
- Ako je skor 85+ ili je klijent već na watchlist-i → zamrzni nalog, hitan kontakt klijentu, prijava nadležnoj službi.
- Ako su u poslednjih 7 dana kumulativno blokirane više od 3 transakcije istog klijenta → automatska eskalacija analitičaru bez obzira na pojedinačni skor.

Ovaj nivo predstavlja vrh forward chaining lanca — pravila ovde rade nad zaključcima donetim u prethodnim koracima (atributi → flegovi → agregati → skor → akcija).

Kompleksna pravila: CEP (Complex Event Processing)

CEP modul prati tokove transakcija i login događaja u realnom vremenu i detektuje obrasce koji se ne mogu uočiti gledanjem pojedinačne transakcije. U sistemu su predviđena sledeća CEP pravila:

- **Velocity attack (card testing):** ako se za istu karticu desi 5 ili više transakcija u roku od 60 sekundi, alarmira se sistem. Tipičan obrazac kada napadač testira ukradenu karticu sa malim iznosima.
- **Impossible travel:** ako se dve transakcije istog klijenta dese na geografskim lokacijama čija razdaljina prevazilazi maksimalno moguće putovanje u vremenskom intervalu (npr. transakcija u Beogradu u 14:00 i u Tokiju u 14:30), alarm se okida.
- **Structuring (smurfing):** ako se u toku 48h desi 3 ili više transakcija čiji su iznosi tačno ispod regulatornog praga prijave (npr. 14.500€ više puta umesto jedne od 50.000€), aktivira se AML alarm. Ovde se koristi accumulate sa filterom po iznosu i klijentu.
- **Burst pattern nakon mirovanja:** ako je nalog bio neaktivan više od 90 dana, a zatim se u jednom danu desi više od 3 transakcije ka različitim primaocima, sumnja se na preuzimanje naloga.
- **Pass-through detekcija:** ako u prozoru od 1h klijent primi iznos X, a zatim u istom prozoru pošalje N puta iznose koji u zbiru čine $\geq 90\%$ od X ka novim primaocima, sumnja se na muling.
- **Failed login burst:** ako se za isti nalog dese 5+ neuspešnih prijava u roku od 5 min, a zatim uspešna prijava sa novog uređaja, generiše se događaj „suspicious_login“ koji ulazi u dalja pravila (account takeover).

Forward chaining

Forward chaining je osnovni mehanizam rezonovanja u sistemu. Pravila se okidaju automatski kada nove činjenice (transakcije, login događaji, promene na nalogu) uđu u radnu memoriju, pri

čemu se zaključci jednog pravila koriste kao ulaz za sledeće pravilo. Lanac rezonovanja u sistemu ima minimalno 4 nivoa:

- **Nivo 1 — Atributi pojedinačne transakcije:** pravila izračunavaju izvedene attribute (poređenje sa istorijom klijenta, vreme, lokacija, merchant kategorija, status uređaja) i dodeljuju flagove poput abnormalno visoka, rizična lokacija, nepoznat uređaj.
- **Nivo 2 — Agregacija ponašanja klijenta (accumulate):** pravila koriste accumulate funkciju nad transakcijama klijenta u vremenskom prozoru (24h, 48h, 7 dana) i prepoznaju obrasce — broj različitih primalaca, odnos odliva i priliva, broj odbijenih transakcija. Rezultat su agregirani flagovi poput muling obrazac i pass-through aktivnost.
- **Nivo 3 — Sinteza skora rizika:** pravila sumiraju težine svih aktivnih flagova iz prethodnih nivoa, primenjuju multiplikatore za segment klijenta (VIP/mladi/penzioneri) i kombinacije više kritičnih flagova, i izračunavaju ukupan skor rizika.
- **Nivo 4 — Odluka o akciji i eskalacija:** pravila na osnovu skora i istorije klijenta odlučuju da li transakcija prolazi, da li se kreira alert, da li se traži step-up autentifikacija, ili se nalog zamrzava. Najviši nivo lanca okida i kumulativna pravila — npr. ako je u 7 dana blokirano 3+ transakcija istog klijenta, automatski se eskalira analitičaru.

Accumulate funkcija se koristi na više mesta u Nivou 2: za prebrojavanje neuspešnih prijava (CEP burst), prebrojavanje različitih primalaca, sumiranje iznosa transakcija u prozoru, i izračunavanje odnosa odliva i priliva. Lanac forward chaining-a od atributa do akcije omogućava da se i najsuptilniji obrasci prevara (poput APP scam-a ili money muling-a) prepoznaju kroz kombinaciju nezavisno detektovanih indikatora.

Backward chaining

Backward chaining (ulančavanje unazad) koristi se za **dijagnostiku**. Za razliku od forward chaining-a, koji se okida automatski kada nove činjenice uđu u radnu memoriju, backward chaining se pokreće **na zahtev** — analitičar (ili pravilo) postavi cilj, a sistem unazad traži činjenice koje ga podržavaju. U Drools-u se realizuje konstrukcijom query.

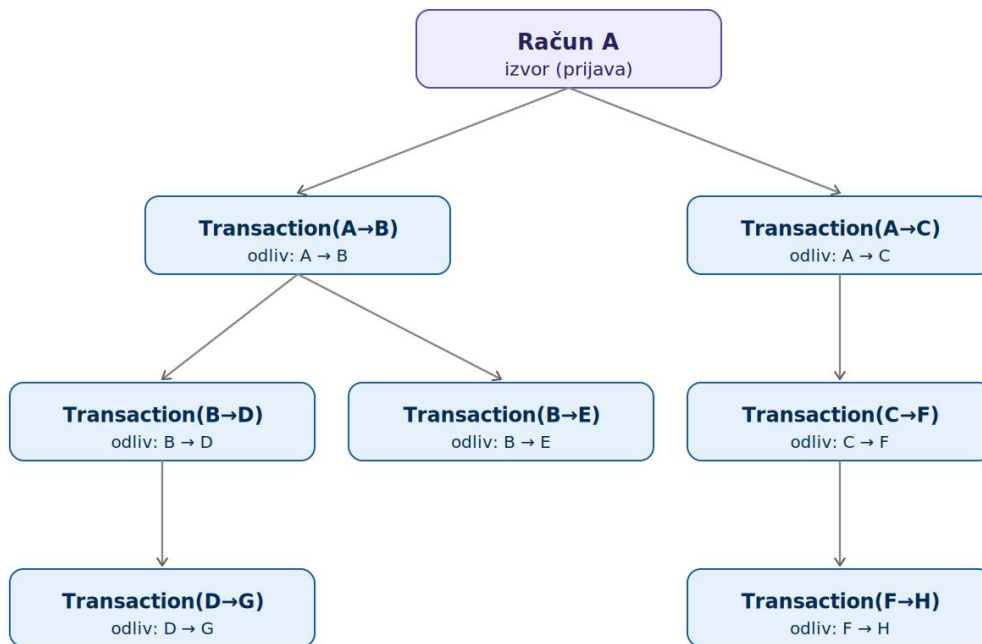
Query i pozicioni argumenti

- Query sadrži samo **LHS** deo pravila (uslovni deo, bez then akcije) i, za razliku od pravila, **može da prima parametre**.
- Pozicioni argumenti omogućavaju proveru jednakosti bez imenovanja atributa: umesto `Cheese( name == n, price == p )` piše se `Cheese( n, p; )` — uz prethodnu deklaraciju `@Position` na poljima klase. U sistemu se za pretragu nad `Transaction` klasom (koja ima više od 20 atributa) koristi imenovani oblik radi čitljivosti.
- Argument može biti **bound** (vezan — ulazni filter) ili **unbound** (nevezan — izlaz koji upit popunjava rešenjima). Isti upit tako služi i za **proveru** konkretne hipoteze i za **nabrajanje** svih rešenja.

Za poziv iz Java koda koristi se `getQueryResults`; za nevezanu promenljivu koristi se `org.kie.api.runtime.rule.Variable.v`.

Hipoteza 1 — Money Mule: rekurzivni upit nad grafom transakcija

Pranje novca se ne može prepoznati gledanjem jednog transfera. Novac putuje kroz **lanac mula naloga proizvoljne dužine** ($A \rightarrow B \rightarrow D \rightarrow G \dots$). U domenu sistema lanac se gradi nad istom klasom `Transaction` koja se koristi i drugde — odlivi se identifikuju filterom `inflow == false`, pri čemu `clientId` igra ulogu pošiljaoca, a `recipientId` primaoca. Svaka takva činjenica je čvor, a lanci grade graf u radnoj memoriji — direktan analog stabla sadržavanja iz JBoss primera (`Location/isContainedIn`).



Svaka Transaction činjenica sa `inflow=false` je čvor; lanci se nadovezuju kao u stablu sadržavanja.

Slika 1. Graf Transaction činjenica (sa `inflow=false`) u radnoj memoriji. Lanci se nadovezuju kao u stablu sadržavanja.

Pitanje „da li novac sa računa A na kraju stiže do računa G kroz proizvoljno mnogo posrednika?“ zahteva **rekurzivni upit**. On ima dve grane: **bazu rekurzije** (postoji direktan odliv) i **rekurzivni korak** (postoji međučvor \$z, pa se upit poziva nad ostatkom lanca). Pošto Transaction klasa nema `@Position` anotacije i sadrži desetak atributa, koriste se **imenovani uslovi** sa `==` umesto pozicionih argumenata:

```

query reaches( String from, String to )
  // baza rekurzije
  Transaction( clientId == from, recipientId == to, inflow == false )
  or
  // rekurzivni korak
  ( Transaction( clientId == from, $z : recipientId, inflow == false )
    and reaches( $z, to; ) )
end

```

Filter `inflow == false` je suštinski — bez njega bi upit obilazio činjenice u oba smera i lažno „pronalazio“ lance. `$z` je nevezana promenljiva koju Drools popuni svakom mogućom vrednošću `recipientId` za dati `from`, pa se nad njom rekurzivno traži ostatak lanca. Pošto je Transaction event sa `@Expires("49h")`, upit prirodno gleda samo lance odmotane u poslednjih 49 sati — što odgovara realnoj brzini kojom muling mreža funkcioniše.

Obilazak se odmotava nivo po nivo — kao `isContainedIn` u gradivu. Sledeći prikaz prati dokazivanje cilja `reaches("A", "G")` (zbog kompaktnosti u prikazu koristi se skraćenica Tx za Transaction):

```
query reaches(String from, String to)
```

```
    Transaction( clientId == from, recipientId == to, inflow == false )
or
    ( Transaction( clientId == from, $z : recipientId, inflow == false )
      and reaches( $z, to; ) )
```

```
end
```

Obilazak (backward chaining) — poziv po poziv:



Rezultat: lanac A → B → D → G postoji ⇒ hipoteza potvrđena

Slika 2. Rekurzivni obilazak: svaki poziv spušta se za jedan nivo niz lanac transakcija dok ne stigne do direktne činjenice.

Pozvan sa **bound** argumentima — `reaches("A", "G";)` — upit proverava konkretnu hipotezu (da li lanac postoji). Pozvan sa **unbound** drugim argumentom — `reaches("A", $thing;)` — vraća **sve** račune do kojih novac sa A stiže, čime se iz jednog upita rekonstruiše cela mreža mula naloga.

```
rule "money_mule_chain"
when
    String( this == "checkMule" )
    $c : Client( $acc : id, suspiciousActivation == true )
    reaches( $acc, $dirtySource; )    // unbound: nađi izvor lanca
then
    insert( new Flag("money_mule", $acc, 40) );
    System.out.println("Mula lanac: novac do " + $acc +
        " potiče iz " + $dirtySource);
end
```

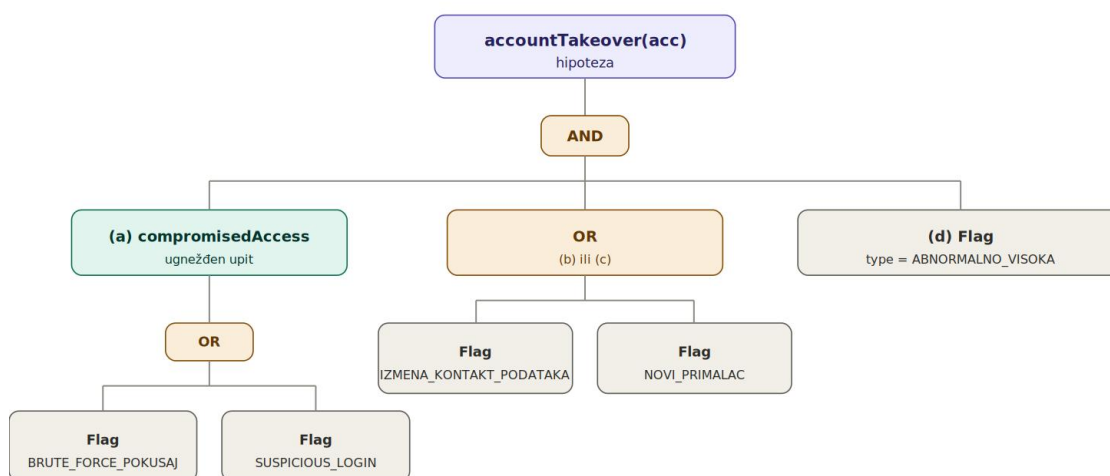
Hipoteza 2 — Account Takeover

Forward chaining tokom Marijinog scenarija već generiše konkretne Flag činjenice u radnoj memoriji: BRUTE_FORCE_POKUSAJ, SUSPICIOUS_LOGIN, IZMENA_KONTAKT_PODATAKA, NOVI_PRIMALAC. Backward chaining query za ATO **ne traži** sirove događaje, već **kombinaciju ovih Flag-ova kao dokaz hipoteze**. Time se pokazuje saradnja dva mehanizma: forward proizvodi flag-ove, backward ih koristi kao listove dokaza.

ATO se potvrđuje kombinacijom dokaza: **(a)** kompromitovan pristup I (b ILI c) izmena kontakta ili dodavanje primaoca I (d) abnormalan transfer. Pomoćni upit compromisedAccess je i sam mali backward-chaining cilj (OR dve mogućnosti — bilo brute force, bilo sumnjiv login), pa se glavni upit oslanja na njega — ugnežđavanje upita:

```
query compromisedAccess( String acc )
  Flag( clientId == acc, type == FlagType.BRUTE_FORCE_POKUSAJ )
  or
  Flag( clientId == acc, type == FlagType.SUSPICIOUS_LOGIN )
end

query accountTakeover( String acc )
  compromisedAccess( acc; ) // (a)
  ( Flag( clientId == acc, type == FlagType.IZMENA_KONTAKT_PODATAKA )
    or Flag( clientId == acc, type == FlagType.NOVI_PRIMALAC ) ) // (b ILI c)
  Flag( clientId == acc, type == FlagType.ABNORMALNO_VISOKA ) // (d)
end
```



Slika 3. Stablo dokaza za accountTakeover — svi listovi su Flag činjenice iz radne memorije.

Svi listovi su iste klase (Flag) — Drools ih razlikuje preko type atributa koji je vrednost iz FlagType enum-a. Ova pravila su tačno onaj skup koji forward chaining već stvara za Marijin scenario; backward chaining ovde služi samo da analitičar može da **imenom pita za hipotezu**, a sistem mu vrati dokaze.

Poziv iz pravila sa **bound** nalogom proverava hipotezu za konkretnog klijenta; poziv sa **unbound** — accountTakeover(acc;) — vraća **listu svih** klijenata kod kojih su uslovi ATO trenutno zadovoljeni (dnevni izveštaj za analitičara).

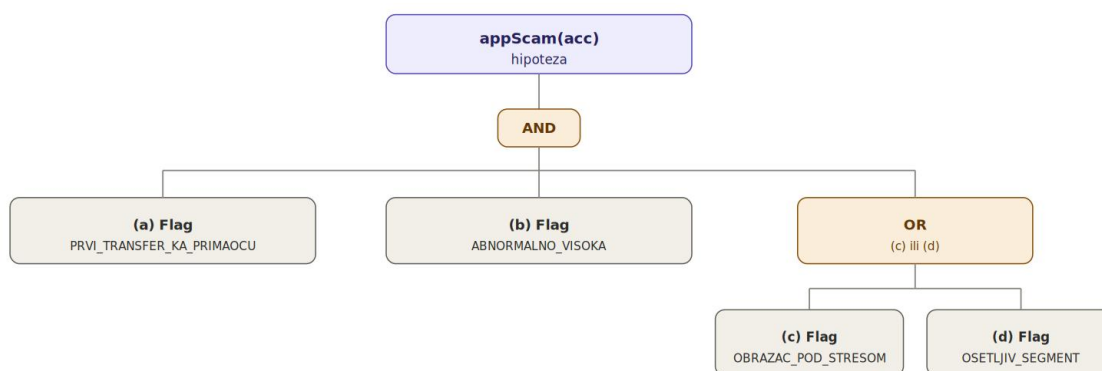
```
rule "diag_account_takeover"
when
  String( this == "go_ato" )
  accountTakeover( acc; ) // unbound acc -> nabraja sve pogođene naloge
then
  System.out.println("Account takeover potvrđen za nalog: " + acc);
end
```

Hipoteza 3 — APP scam (autorizovana prevara)

Olgin scenario forward chaining generiše Flag-ove PRVI_TRANSFER_KA_PRIMAOCU, ABNORMALNO_VISOKA, OBRAZAC_POD_STRESOM, OSETLJIV_SEGMENT. Backward chaining upit ih kombinuje da bi potvrdio APP scam hipotezu.

Najsuptilniji slučaj — transakciju izvršava pravi vlasnik. Cilj se potvrđuje kao (a) prvi transfer ka primaocu I (b) neuobičajen iznos I (c) ILI (d) bihevioralni indikator stresa ili pripadnost osetljivom segmentu:

```
query appScam( String acc )
  Flag( clientId == acc, type == FlagType.PRVI_TRANSFER_KA_PRIMAOCU ) // (a)
  Flag( clientId == acc, type == FlagType.ABNORMALNO_VISOKA ) // (b)
  ( Flag( clientId == acc, type == FlagType.OBRAZAC_POD_STRESOM ) // (c)
    or Flag( clientId == acc, type == FlagType.OSETLJIV_SEGMENT ) ) // (d)
end
```



Slika 4. Stablo dokaza za appScam — kombinacija Flag činjenica koje je forward chaining već stvorio.

Sva četiri lista su Flag činjenice koje forward chaining već generiše — ATO i APP upiti time postaju **dijagnostički sloj nad postojećim flag stream-om**, što je tačno uloga backward chaining-a u sistemu: ne radi novu detekciju, već kombinuje postojeće dokaze u imenovane hipoteze. Kao i kod ATO, upit se zove sa **bound** acc za proveru konkretnog slučaja, ili **unbound** za dnevni izveštaj svih klijenata kod kojih su uslovi APP scam-a trenutno zadovoljeni.

Backward chaining kao mehanizam objašnjenja

Pošto svaki query gradi eksplicitan lanac dokaza (koje su tačno činjenice potvrdile cilj), backward chaining istovremeno daje i **objašnjenje**. Kada analitičar pita „zašto je ovo označeno?“, sistem rekonstruiše niz činjenica — za muling ceo lanac Transfer čvorova od izvora do odredišta — što je ključno zbog regulative (GDPR, PSD2) i prednost nad modelima mašinskog učenja koji ne mogu da obrazlože odluku.

Template

Template pravila omogućavaju administratoru da menja parametre baze znanja **bez prekompajliranja**. Logika pravila se piše jednom, sa „prazninama“ oblika `@{parametar}`, a konkretne vrednosti dolaze iz **tabele parametara** koju administrator uređuje. Iz jednog template-a i jedne tabele Drools generiše po jedno konkretno pravilo za svaki red tabele. U nastavku je za svaki template dat kostur i tačni parametri.

A) Pragovi rizika po segmentima klijenata

Cut-off vrednosti skora razlikuju se po segmentu — VIP klijenti imaju viši prag za blokadu jer su navikli na velike iznose, dok osetljivi segmenti (mladi, penzioneri) imaju niže pragove. Kostur template-a:

```
template "risk_thresholds"
rule "thresholds_@{segment}"
when
    $c : Client( segment == "@{segment}", $s : riskScore )
then
    applyThresholds($c, @{alertCut}, @{blockCut}, @{freezeCut});
end
end template
```

Parametri (vrednosti skora 0–100):

segment	alertCut	blockCut	freezeCut	logCut (nizak)
VIP	35	70	90	0–35
redovni	30	60	85	0–30
mladi (18–25)	25	50	80	0–25
penzioneri (65+)	25	50	80	0–25

Iz ove tabele generišu se **4 pravila** (po jedno za svaki segment). Ako administrator podigne blockCut za VIP sa 70 na 75, sistem to koristi odmah, bez izmene koda.

B) Crna i siva lista zemalja

Administrator dodaje ili uklanja zemlje; template generiše pravilo evaluacije po zemlji. Crna lista vodi na blokadu, siva na flag sa težinom.

```
template "country_lists"
rule "country_@{countryCode}"
when
    $t : Transaction( country == "@{countryCode}" )
then
    applyCountryAction($t, "@{listType}", @{weight});
end
end template
```

Parametri:

countryCode	listType	weight	akcija
KP	crna	40	blokada + flag

countryCode	listType	weight	akcija
IR	crna	40	blokada + flag
MM	crna	40	blokada + flag
PA	siva	15	samo flag
KY	siva	15	samo flag
... (FATF lista)	siva	15	samo flag

C) Kategorije visokorizičnih merchant-a (MCC kodovi)

Konfigurabilna lista MCC (Merchant Category Code) kodova; svaki nosi sopstvenu težinu flega rizičan merchant.

```
template "high_risk_mcc"
rule "mcc_@{mcc}"
when
    $t : Transaction( merchantCategory == @{mcc} )
then
    insert( new Flag("rizican_merchant", $t.getClientId(), @{weight}) );
end
end template
```

Parametri:

MCC	kategorija	weight
7995	kockanje / klađenje	25
6051	kripto-menjačnice	25
6540	prepaid kartice	20
4829	novčani transferi	20

D) Vremenski prozori za CEP pravila

Dužina prozora i pragovi okidanja za svako CEP pravilo. Template generiše deklaraciju prozora i prag, pa se izmene zakona/politike unose bez diranja logike detekcije.

```
template "cep_windows"
rule "cep_@{ruleName}"
when
    Number( $n : intValue >= @{minCount} ) from accumulate(
        $e : Event( clientId == $cid ) over window:time( @{windowLen} ),
        count($e) )
then
    insert( new Flag("@{ruleName}", $cid, @{weight}) );
end
end template
```

Parametri:

ruleName	windowLen	minCount	dodatni prag	weight
velocity (card testing)	60s	5	—	25

ruleName	windowLen	minCount	dodatni prag	weight
failed_login_burst	5m	5	+ nov uređaj	25
impossible_travel	6h	2	> 900 km/h	30
structuring	48h	3	iznos < AML prag	30
pass_through	1h	—	odliv ≥ 90%	20
burst_after_idle	24h	3	nakon 90d mira	20

E) Regulatorni pragovi (AML cut-off iznosi)

Prag prijave razlikuje se po jurisdikciji i menja se izmenama zakona. Template generiše pravilo strukturiranja (structuring) po jurisdikciji — okida se kada je iznos tačno ispod praga prijave.

```
template "aml_thresholds"
rule "aml_{jurisdiction}"
when
    $t : Transaction( jurisdiction == "@{jurisdiction}",
                      amount > @{nearThreshold}, amount < @{reportThreshold} )
then
    insert( new Flag("structuring", $t.getClientId(), 30) );
end
end template
```

Parametri:

jurisdiction	reportThreshold	nearThreshold (90%)	valuta
EU	10.000	9.000	EUR
Srbija	15.000	13.500	RSD (ekv.)
SAD	10.000	9.000	USD
UK	10.000	9.000	GBP

Kod „near threshold“ strukturiranja, prevaranti šalju iznose tik ispod praga prijave (npr. više puta po 14.500€ umesto jedne transakcije od 50.000€). Parametar nearThreshold definiše donju granicu sumnjivog opsega (~90% praga), a reportThreshold gornju (regulatorni prag). Izmenom dva broja u tabeli pravilo se prilagođava novoj jurisdikciji ili izmeni zakona.

Konkretan primer rezonovanja (korak po korak)

U nastavku je prikazan scenario u kome se kombinuju sva tri napredna mehanizma (forward chaining sa accumulate, CEP i backward chaining).

Scenario: Klijentkinja Marija (45 godina, segment „redovni“, prosečan mesečni promet 2.500€, prebivalište Srbija) je žrtva account takeover napada. Sled događaja koje sistem obrađuje:

1. U 22:14 — 5 neuspešnih pokušaja prijave na e-banking u roku od 3 minuta sa IP adrese iz Holandije.
2. U 22:18 — uspešna prijava sa istog IP-a, sa uređaja koji nije u listi poznatih uređaja klijentkinje.
3. U 22:21 — promena email adrese za notifikacije.

4. U 22:25 — dodavanje novog primaoca („Petar P.“, račun u inostranoj banci).
5. U 22:27 — pokušaj transfera od 4.800€ ka novom primaocu.

Korak 1 — CEP detekcija sumnjivog logina

CEP modul detektuje obrazac „failed login burst → successful login from new device“ u događajima 1 i 2. Generiše se činjenica SuspiciousLogin(klijent=Marija, vreme=22:18, novaZemlja=Holandija, noviUredjaj=true). Ova činjenica ulazi u radnu memoriju i postaje okidač za dalja pravila.

Korak 2 — Forward chaining, Nivo 1 (atributi transakcije)

Kada u 22:27 stigne pokušaj transfera, pravila Nivoa 1 se okidaju i izračunavaju: iznos=4800 što je 1.92x prosečnog mesečnog prometa (flag abnormalno visoka); primalac je nov (flag novi primalac); transakcija je u 22:27 — neuobičajeno vreme za ovog klijenta (flag neuobičajeno vreme); uređaj sa kojeg je inicirana je nepoznat (flag nepoznat uređaj).

Korak 3 — Forward chaining, Nivo 2 (agregacija — accumulate)

Pravilo sa accumulate funkcijom prebrojava promene na nalogu u poslednjih 60 minuta: accumulate(AccountChange(clientId == "Marija", time after [-60min]); count). Rezultat je 2 (promena email-a + novi primalac). Pravilo zaključuje da je u toku burst aktivnosti na nalogu.

Korak 4 — Forward chaining, Nivo 3 (skor rizika)

Pravilo sinteze sumira flegove i njihove težine: nepoznat uređaj (15) + abnormalno visoka (20) + novi primalac (15) + neuobičajeno vreme (10) + suspicious login iz Koraka 1 (25) + burst aktivnosti (20) = bazni skor 105. Pošto se kombinuju 3+ kritična flega, primenjuje se multiplikator 1.2 → finalni skor 126 (klampuje se na 100). Klasifikacija: KRITIČAN RIZIK.

Korak 5 — Forward chaining, Nivo 4 (akcija)

Pravilo eskalacije se okida: zbog kritičnog skora — transakcija se BLOKIRA, nalog se ZAMRZAVA, generiše se hitan alert za analitičara, klijentkinja se kontaktira telefonskim pozivom (ne SMS-om jer je email već promenjen — komunikacioni kanali mogu biti kompromitovani).

Korak 6 — Backward chaining (dijagnostika)

Analitičar otvara slučaj i poziva upit accountTakeover("MARIJA_001";). Sistem unazad proverava da li u radnoj memoriji postoje Flag činjenice koje dokazuju hipotezu (sve ih je forward chaining već stvorio tokom Koraka 1–5):

- **(a)** compromisedAccess → DA — Flag(BRUTE_FORCE_POKUSAJ) iz Koraka 1 (failed login burst).
- **(b)** Flag(IZMENA_KONTAKT_PODATAKA) → DA — promena email-a u 22:21.
- **(c)** Flag(NOVI_PRIMALAC) → DA — Petar P. dodat u 22:25 (OR grana, jedno od dva je dovoljno).
- **(d)** Flag(ABNORMALNO_VISOKA) → DA — transfer 4.800€ je 19.2× prosek (Korak 5).

Sistem vraća: hipoteza POTVRĐENA sa visokim stepenom poverenja. Analitičar dobija strukturirano objašnjenje (tačnu listu Flag-ova koji su dokazali svaku granu), kontaktira klijentkinju, vraća lozinku, uklanja kompromitovanog primaoca i prijavljuje slučaj kao Account Takeover. Slučaj postaje deo training seta za buduće prilagođavanje težina pravila.